1. Functional and Non-Functional Requirements

HackTheAPI // OWASP API Security Training & Assessment Platform

---

■ 1. Executive Overview

HackTheAPI is an enterprise-grade, interactive API security training and assessment platform designed to deliver hands-on vulnerability labs covering the **OWASP API Security Top 10**. The platform integrates containerized vulnerability labs, independent server-side evaluation, adaptive AI mentoring, and transfer-learning analytics.

■■ 2. Functional Requirements (FR)

FR-1: Multi-Tenant Role-Based Access Control (RBAC)

- **FR-1.1**: The system MUST support four (4) distinct user roles: **`Student`**, **`Instructor`**, **`Assessor`**, and **`Platform Administrator`**.
- **FR-1.2**: Access to administrative API endpoints, instructor analytics, and assessor portals MUST be strictly restricted based on JWT claims and server-side role permissions.

FR-2: Authentication & Email Verification

- **FR-2.1**: User authentication MUST be handled via stateless JSON Web Tokens (JWT) issued upon successful credential verification.
- **FR-2.2**: Password resets MUST dispatch real 6-digit verification codes via Gmail SMTP (**`smtp.gmail.com:587`**).
- **FR-2.3**: Password reset tokens MUST enforce a strict **3-attempt rate limit** before automatic revocation to prevent code brute-forcing.

FR-3: 12 OWASP Top 10 API Security Vulnerability Labs

- **FR-3.1**: The platform MUST host 12 distinct hands-on API security vulnerability labs:
- **`ex-bola-01`** — Broken Object Level Authorization (**BOLA / IDOR**) (**`API1:2023`**)
- **`ex-bfla-01`** — Broken Function Level Authorization (**BFLA**) (**`API2:2023`**)
- **`ex-mass-01`** — **Mass Assignment** Property Injection (**`API3:2023`**)
- **`ex-rate-01`** — **Unrestricted Rate Limiting** OTP Brute Force (**`API4:2023`**)
- **`ex-ssrf-01`** — **Server-Side Request Forgery** Cloud Metadata Leak (**`API7:2023`**)
- **`ex-jwt-01`** — **JWT None Algorithm** Authentication Bypass (**`API8:2023`**)
- **`ex-sqli-01`** — **SQL Injection** User Search API (**`API8:2023`**)
- **`ex-cors-01`** — **Arbitrary Origin CORS** Exfiltration (**`API8:2023`**)
- **`ex-cmdi-01`** — **OS Command Injection** PDF Exporter (**`API10:2023`**)
- **`ex-xxe-01`** — **XML External Entity (XXE)** Injection (**`API5:2023`**)
- **`ex-nosql-01`** — **NoSQL Injection** Auth Bypass (**`API3:2023`**)
- **`ex-graphql-01`** — **GraphQL Introspection** Field Disclosure (**`API9:2023`**)

FR-4: Interactive OpenAPI Payload Workbench

• **FR-4.1**: The frontend MUST provide an interactive HTTP Request Builder allowing students to customize HTTP Methods (**`GET`**, **`POST`**, **`PUT`**, **`DELETE`**, **`PATCH`**), endpoints, headers, and body payloads.

• **FR-4.2**: The workbench MUST feature 1-click loading of sample exploit payloads and documentation endpoints (**`/api/v1/docs`**).

FR-5: Server-Side Independent Oracle Verification Engine

• **FR-5.1**: Verification MUST run independently on the server backend without reliance on client-side state flags.

• **FR-5.2**: The Oracle Engine MUST execute dual evaluations:

• *Request/Response Evaluator*: Validates HTTP status code, response payload, and exfiltrated parameters.

• *Database State Evaluator*: Verifies physical backend database state changes (e.g. user deletion, role elevation).

FR-6: Local Ollama Qwen AI Learning Assistant & Real-Time Context Reader

• **FR-6.1**: The platform MUST integrate a local Ollama LLM service (**`http://127.0.0.1:11434`**) using **`qwen2.5-coder`** / **`qwen:latest`** with zero third-party cloud data leakage.

• **FR-6.2**: When a student asks *"guide me through this"*, the assistant MUST inspect the **entire frontend screen context** (**`window.__CURRENT_LAB_WORKBENCH_STATE__`**): active exercise ID, OWASP category, scenario, request builder method, endpoint, headers, body, and last execution response.

FR-7: Transfer Learning & Skill Assessment Engine

• **FR-7.1**: The platform MUST conduct Pre-Test (baseline) and Post-Test (evaluation) assessments to measure knowledge transfer velocity across security dimensions.

FR-8: Instructor & Assessor Analytics Dashboards

• **FR-8.1**: Instructors MUST be able to inspect real-time student completion rates, average scores, and cohort performance.

• **FR-8.2**: Administrators MUST have full authority to manage users, nullify passwords, switch roles, and review security audit logs.

■ 3. Non-Functional Requirements (NFR)

NFR-1: Performance & Latency

• **NFR-1.1**: Backend REST API endpoints MUST respond within **< 100ms** under normal load.

• **NFR-1.2**: Local Ollama AI response generation MUST complete within **< 2.5 seconds** for contextual guidance queries.

NFR-2: Security & Privacy

• **NFR-2.1**: All local LLM queries MUST remain within the host environment (**`127.0.0.1:11434`**) to ensure zero student data leakage to external cloud APIs.

• **NFR-2.2**: Password hashes MUST be encrypted using Django default PBKDF2 with SHA-256 password hashing algorithm.

NFR-3: Container Isolation & Scalability

• **NFR-3.1**: Target vulnerability labs MUST run inside isolated Docker container subnets per student lab session to prevent cross-tenant interference.

NFR-4: Usability & User Experience (UX)

• **NFR-4.1**: The Qwen AI panel MUST function as a floating drawer side panel (**`width: 420px`**) with top-left close button (**X**) and smooth page reflow padding adjustment (**`padding-right: 420px`**).

NFR-5: Reliability & Availability

• **NFR-5.1**: If the local Ollama service is offline, the AI assistant MUST fail gracefully by displaying clear startup instructions (**`ollama run qwen2.5-coder`**) rather than crashing or displaying broken UI components.